

Sistemi e Reti - Sessione straordinaria 2024 (Seconda prova scritta)

Ministero dell'istruzione e del merito

A038 - ESAME DI STATO CONCLUSIVO DEL SECONDO CICLO DI ISTRUZIONE

Indirizzo ITIA - INFORMATICA E TELECOMUNICAZIONI Articolazione "INFORMATICA"

(Testo valevole anche per gli indirizzi quadriennali IT32)

Disciplina: SISTEMI E RETI

Il candidato svolga la prima parte della prova e due tra i quesiti proposti nella seconda parte.

PRIMA PARTE

Azienda Informatica con nuova sede staccata

Un'azienda informatica in forte espansione ha acquisito un capannone per realizzare una nuova sede **in una città diversa** da quella in cui si trova la sede principale.

Presso tale capannone l'azienda vuole realizzare tre distinti reparti di produzione software in cui lavoreranno gli sviluppatori:

- Reparto A) Sviluppo applicazioni mobile
- Reparto B) Sviluppo siti web
- Reparto C) Sviluppo software di settore (es. gestione ospedaliera, gestione agenzie di trasporti, etc.)

Sono inoltre previsti i seguenti ulteriori reparti:

- Reparto D) Test di qualità
- Reparto E) Project management
- Reparto F) Amministrazione per la gestione della sede locale

Ciascun addetto necessita di una propria postazione dotata di computer desktop aziendale; l'allocazione dei computer prevista per ciascun reparto è descritta dalla seguente tabella:

Reparto	A	B	C	D	E	F
N° computer	50	30	100	20	10	20

Ogni reparto prevede inoltre fino ad un **10% di computer di riserva** per sopperire ad eventuali guasti.

L'accesso a ciascun computer deve avvenire previa **autenticazione** dell'utente.

Ogni sviluppatore dei reparti A, B, C deve potere accedere ad internet, ad una **stampante di rete** e ad un **file server** entrambi collocati **nel proprio reparto**, mentre non deve essergli consentito di accedere ai sistemi interni di altri reparti.

Gli operatori del **reparto D devono potere accedere ai file server locali dei reparti A, B, C** per potere effettuare i test sui progetti e qualora un test risulti superato lasciare un report nella relativa cartella, rinominarla aggiungendo al nome della cartella un suffisso per marcare il progetto come terminato (es. "_Final_Version") e renderla "read-only".

I Project manager del reparto E devono potere accedere a tutti i file server locali del capannone e devono inoltre, ogni qualvolta si ha una versione terminata di un determinato progetto, trasferirne i file su un sistema server remoto (**project repository**) **dislocato presso la sede centrale**, aggiungendo la documentazione ed i manuali.

L'amministrazione del reparto F deve potere accedere ad internet ed al sistema gestionale **remoto** presso la sede centrale.

Il candidato analizzi la realtà di riferimento e, fatte le opportune ipotesi aggiuntive, sviluppi i seguenti punti:

1. un progetto **di massima** dell'infrastruttura della rete della nuova sede, anche supportato da uno schema grafico, prevedendo
 - **struttura delle sottoreti**,
 - **apparati**,

- servizi implementati,
 - tipologia delle connessioni interne e verso Internet ed
 - un opportuno piano di indirizzamento dei sistemi;
2. le misure ed i sistemi per la gestione della sicurezza **interna** ed esterna;
 3. modalità e protocolli di collegamento verso i sistemi remoti nella sede centrale;
 4. dettagli di configurazione di uno dei servizi.
-

SECONDA PARTE

Quesito I

In relazione al tema proposto nella prima parte, si ipotizzi che **presso la sede centrale** siano inoltre presenti, in aggiunta al server remoto (project repository) ed al sistema gestionale, una serie di **server pubblici** per offrire i seguenti servizi:

- server web aziendale per la pubblicazione del sito di e-commerce dei propri prodotti
- mail aziendale

Descrivere tale parte dell'infrastruttura di rete dell'azienda.

Quesito II

In relazione al tema proposto nella prima parte, si immagini di voler virtualizzare i vari server locali su un unico server fisico.

Il candidato illustri:

- quali modifiche all'infrastruttura di rete e alla sua configurazione logica e fisica si renderebbero eventualmente necessarie
 - la differenza tra il software di virtualizzazione nativo (tipo 1) e quello ospitato in un sistema operativo (tipo 2)
-

Quesito III

Il candidato esponga le caratteristiche in termini di sicurezza dei protocolli disponibili per la protezione delle reti WiFi, quali ad esempio:

WEP, WPA, WPA2 e WPA3 (questi ultimi sia personal che enterprise),
e le principali differenze tra essi.

Quesito IV

Il candidato esponga le modalità di lavoro dei diversi tipi di firewall e degli application gateway (proxy), evidenziandone le peculiarità ed i diversi campi di applicazione.

Note finali

Durata massima della prova: 6 ore

È consentito l'uso di manuali tecnici e di calcolatrici scientifiche o grafiche purché non siano dotate della capacità di elaborazione simbolica algebrica e non abbiano la disponibilità di connessione a Internet.

È consentito l'uso del dizionario bilingue (italiano-lingua del paese di provenienza) per i candidati di madrelingua non italiana.

Non è consentito lasciare l'Istituto prima che siano trascorse 3 ore dalla consegna della traccia.

PRIMA PARTE - Soluzione

1. Ipotesi progettuali

La nuova sede viene progettata come rete aziendale separata dalla sede centrale ma collegata tramite **VPN site-to-site**.

Si adottano queste scelte:

- rete cablata Gigabit Ethernet per le postazioni,
- dorsali in fibra o rame 10 GbE tra armadio centrale e armadi di piano/reparto,
- VLAN separate per reparti e server,
- autenticazione centralizzata degli utenti,
- firewall perimetrale con VPN verso la sede centrale,
- ACL/firewall **interni** per impedire accessi non autorizzati tra reparti.

La separazione tra reparti è necessaria perché la traccia richiede che - gli sviluppatori dei reparti A, B e C **non** accedano ai sistemi interni degli altri reparti.

- I reparti D ed E hanno invece permessi trasversali, ma diversi: - D (test & qualità) deve accedere ai file server A/B/C per test e marcatura delle versioni finali;
- E (project manager) deve accedere a tutti i file server e trasferire le versioni definitive al repository remoto.

2. Dimensionamento delle postazioni

La traccia prevede anche un 10% di computer di riserva.

Reparto	Funzione	PC previsti	Riserva 10%	Totale minimo
A	sviluppo mobile	50	5	55
B	sviluppo siti web	30	3	33
C	sviluppo software di settore	100	10	110
D	test qualità	20	2	22
E	project management	10	1	11
F	amministrazione sede locale	20	2	22

Si aggiunge margine per stampanti, server, apparati, crescita futura e gestione.

3. Architettura generale della nuova sede

Si propone una rete a **due livelli**, adatta a una sede di queste dimensioni:

- **livello accesso:** switch di reparto per PC, stampanti e server locali;
- **livello core/distribution:** coppia di switch centrali Layer 3 o switch centrale ridondato, collegato al firewall.

Il **routing tra VLAN** viene concentrato sul core L3 oppure sul firewall. In questa soluzione si sceglie routing **centralizzato su firewall/NGFW per le VLAN più sensibili**, perché il controllo tra reparti è un requisito importante della traccia. Il core switch gestisce trunk, aggregazioni e connettività interna, mentre il firewall applica le policy principali tra VLAN.

4. Diagramma conciso

Internet

Router ISP

Firewall / NGFW nuova sede

VPN IPsec site-to-site

Sede centrale

-- Project repository remoto

-- Sistema gestionale remoto

Core switch L3 / Distribution

- |-- VLAN 10 - Reparto A utenti
- |-- VLAN 11 - Server A
- |-- VLAN 20 - Reparto B utenti
- |-- VLAN 21 - Server B
- |-- VLAN 30 - Reparto C utenti
- |-- VLAN 31 - Server C
- |-- VLAN 40 - Reparto D test qualità
- |-- VLAN 50 - Reparto E project management
- |-- VLAN 60 - Reparto F amministrazione
- |-- VLAN 70 - Servizi infrastrutturali
- |-- VLAN 80 - Management apparati
- |-- VLAN 90 - WiFi ospiti, opzionale
- |-- VLAN 99 - Backup

Diagramma dettagliato

INTERNET

Infrastruttura di rete del provider ISP

MEZZO TRASMISSIVO WAN

Fibra ottica FTTH business
(collegamento fisico WAN)

DISPOSITIVO ISP
ONT FTTH + Router/CPE business provider
Funzioni tipiche:

- terminazione collegamento WAN
- accesso alla rete ISP
- eventuale PPPoE/MPLS/BGP

DISPOSITIVO AZIENDALE
Firewall / NGFW nuova sede
Funzioni:

- routing tra VLAN
- routing verso Internet
- routing verso VPN site-to-site
- NAT/PAT
- ACL inter-VLAN
- IDS/IPS
- filtraggio applicativo
- logging e monitoraggio

DISPOSITIVO AZIENDALE
Core Switch Layer 3 / Distribution
Funzioni:

- | - switching centrale
- | - trunk VLAN 802.1Q
- | - aggregazione collegamenti
- | - eventuale routing locale controllato

=====

RETE LAN AZIENDALE

=====

VLAN 10 - Utenti reparto A

10.24.10.0/26

Dispositivi:

- PC sviluppo mobile

VLAN 11 - Servizi reparto A

10.24.11.0/28

Dispositivi:

- File Server A
- Stampante A

VLAN 20 - Utenti reparto B

10.24.20.0/26

Dispositivi:

- PC sviluppo web

VLAN 21 - Servizi reparto B

10.24.21.0/28

Dispositivi:

- File Server B
- Stampante B

VLAN 30 - Utenti reparto C

10.24.30.0/25

Dispositivi:

- PC sviluppo software

VLAN 31 - Servizi reparto C

10.24.31.0/28

Dispositivi:

- File Server C
- Stampante C

VLAN 40 - Reparto D Test QA

10.24.40.0/27

Dispositivi:

- PC tester

VLAN 50 - Project Management

10.24.50.0/28

Dispositivi:

- PC project manager

VLAN 60 - Amministrazione

10.24.60.0/27

Dispositivi:

- PC amministrazione

VLAN 70 - Servizi infrastrutturali

10.24.70.0/27

Dispositivi:

- AD/LDAP
- DNS


```

- DHCP
- RADIUS
- Logging server

-----
VLAN 80 - Management apparati
10.24.80.0/28
Dispositivi:
- Console amministrazione
- Management switch
- Management firewall
- Management access point

-----
VLAN 90 - WiFi ospiti
10.24.90.0/24
Dispositivi:
- client WiFi ospiti
- solo accesso Internet

-----
VLAN 99 - Backup
10.24.99.0/27
Dispositivi:
- Backup server
- Replica dati

```

=====

COLLEGAMENTO TRA SEDI

=====

```

Nuova sede
10.24.0.0/16

```

```

+-----+
| DISPOSITIVO AZIENDALE |
| Firewall nuova sede   |
+-----+

```

=====

MEZZO TRASMISSIVO WAN / INTERNET

=====

```

Tunnel VPN IPsec cifrato

```

```

+-----+
| DISPOSITIVO AZIENDALE |
| Firewall sede centrale |
+-----+

```

```

Sede centrale
10.10.0.0/16

```

```

|-- Project repository
|-- Sistema gestionale

```

=====

ACCESSI PRINCIPALI

=====

```

Reparto A

```

```

-> Internet
-> File Server A
-> Stampante A
X nessun accesso ai sistemi B e C

```

```

Reparto B

```

```

-> Internet

```


- > File Server B
- > Stampante B
- X nessun accesso ai sistemi A e C

Reparto C

- > Internet
- > File Server C
- > Stampante C
- X nessun accesso ai sistemi A e B

Reparto D (Test QA)

- > accesso controllato ai File Server A/B/C

Reparto E (Project Management)

- > accesso ai File Server A/B/C
- > trasferimento versioni finali verso sede centrale

Reparto F (Amministrazione)

- > Internet
- > sistema gestionale remoto sede centrale

5. Diagramma grafico

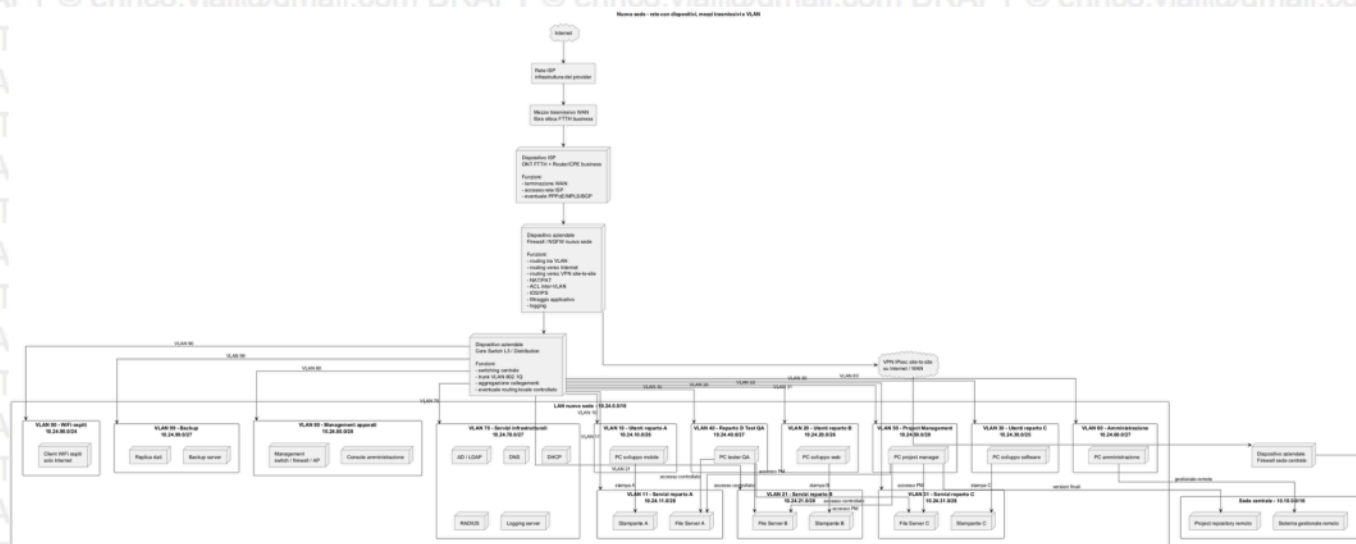


Figure 1: PlantUML 1

6. Piano VLAN e indirizzamento

Rete scelta nuova sede: 10.24.0.0/16 cioè una rete privata RFC1918.

10.24.0.0/16 è stata scelta perché sufficientemente ampia per molte VLAN e future espansioni.

Il prefisso /16 semplifica inoltre la suddivisione ordinata delle sottoreti. Sono state escluse - reti più piccole, ad esempio /24, perché poco scalabili

- 172.16.0.0/12 sarebbe stata tecnicamente corretta, ma offre meno flessibilità complessiva e viene più spesso utilizzata in reti di dimensioni medio-piccole. - reti pubbliche perché gli indirizzi interni aziendali devono normalmente usare indirizzi privati non instradabili su Internet.

Le sottoreti sono definite con VLSM.

Il reparto C richiede almeno 110 host, quindi si usa /25.

I reparti A, B, D, F richiedono meno host ma ricevono margine sufficiente.

In una soluzione professionale i server sono separati dagli utenti per applicare regole di sicurezza, se seguiamo questo approccio, correttissimo, abbiamo un grande numero di reti.

VLAN	Nome rete	Subnet	Gateway	Host utilizzabili	Uso
10	Utenti reparto A	10.24.10.0/26	10.24.10.1	10.24.10.1 - 10.24.10.62	PC sviluppo mobile

VLAN	Nome rete	Subnet	Gateway	Host utilizzabili	Uso
11	Server reparto A	10.24.11.0/28	10.24.11.1	10.24.11.1 - 10.24.11.14	file server A, stampante A
20	Utenti reparto B	10.24.20.0/26	10.24.20.1	10.24.20.1 - 10.24.20.62	PC sviluppo web
21	Server reparto B	10.24.21.0/28	10.24.21.1	10.24.21.1 - 10.24.21.14	file server B, stampante B
30	Utenti reparto C	10.24.30.0/25	10.24.30.1	10.24.30.1 - 10.24.30.126	PC sviluppo settore
31	Server reparto C	10.24.31.0/28	10.24.31.1	10.24.31.1 - 10.24.31.14	file server C, stampante C
40	Reparto D	10.24.40.0/27	10.24.40.1	10.24.40.1 - 10.24.40.30	test qualità
50	Reparto E	10.24.50.0/28	10.24.50.1	10.24.50.1 - 10.24.50.14	project manager
60	Reparto F	10.24.60.0/27	10.24.60.1	10.24.60.1 - 10.24.60.30	amministrazione
70	Servizi locali	10.24.70.0/27	10.24.70.1	10.24.70.1 - 10.24.70.30	AD/LDAP, DNS, DHCP, RADIUS
80	Management	10.24.80.0/28	10.24.80.1	10.24.80.1 - 10.24.80.14	apparati e console admin
90	WiFi ospiti	10.24.90.0/24	10.24.90.1	10.24.90.1 - 10.24.90.254	ospiti, solo Internet
99	Backup	10.24.99.0/27	10.24.99.1	10.24.99.1 - 10.24.99.30	backup e replica

Negli intervalli “host utilizzabili” è stato incluso anche il gateway; per assegnazioni ai client(dispositivi utente) spesso negli esercizi si “riserva” il router (host ID 1) e si parte dal secondo indirizzo utile.

Nel mondo reale a volte il router può avere l’host ID immediatamente precedente il broadcast.

7. Matrice dei principali sistemi

Sistema	VLAN	IP proposto	Note
Gateway VLAN 10	10	10.24.10.1	firewall o SVI controllata
File server A	11	10.24.11.10	accesso A, D, E
Stampante A	11	10.24.11.11	accesso solo A
Gateway VLAN 20	20	10.24.20.1	utenti reparto B
File server B	21	10.24.21.10	accesso B, D, E
Stampante B	21	10.24.21.11	accesso solo B
Gateway VLAN 30	30	10.24.30.1	utenti reparto C
File server C	31	10.24.31.10	accesso C, D, E
Stampante C	31	10.24.31.11	accesso solo C
Server AD/LDAP	70	10.24.70.10	autenticazione utenti
DNS interno	70	10.24.70.11	risoluzione nomi
DHCP	70	10.24.70.12	indirizzi dinamici
RADIUS	70	10.24.70.13	802.1X cablato/WiFi
Backup server	99	10.24.99.10	backup file server
Console admin	80	10.24.80.10	gestione apparati
Firewall interno	varie	.1 su ogni VLAN	gateway e policy

Piano semplificato

In una prova d’esame per avere meno reti potrebbe essere accettabile porre file server e stampante nella rete di reparto, ciò normalmente è sconsigliabile nel mondo reale dato che diminuisce la possibilità di applicare regole di sicurezza.

Il piano semplificato usa sempre 10.24.0.0/16, rete privata RFC1918.

Nome		Router / interfaccia		Primo host	Host		
VLAN	Subnet	Gateway	VLAN	Broadcast	utente	utilizzabili	Dispositivi principali
90	WiFi ospiti	10.24.90.0/24	10.24.90.1	10.24.90.255	10.24.90.2	254	client ospiti, solo Internet
30	Reparto C	10.24.30.0/28	10.24.30.1	10.24.30.127	10.24.30.20	126	PC C, File Server C, Stampante C
10	Reparto A	10.24.10.0/28	10.24.10.1	10.24.10.63	10.24.10.20	62	PC A, File Server A, Stampante A
20	Reparto B	10.24.20.0/28	10.24.20.1	10.24.20.63	10.24.20.20	62	PC B, File Server B, Stampante B
40	Reparto D	10.24.40.0/28	10.24.40.1	10.24.40.31	10.24.40.10	30	PC test qualità

VLAN	Nome Rete	Subnet	Gateway	Router / interfaccia VLAN	Broadcast	Primo host utente	Host utilizzabili	Dispositivi principali
60	Reparto F	10.24.60.0/24	10.24.60.1	10.24.60.1	10.24.60.31	10.24.60.10	30	PC amministrazione
70	Servizi locali	10.24.70.0/24	10.24.70.1	10.24.70.1	10.24.70.31	non applicabile	30	AD/LDAP, DNS, DHCP, RADIUS, logging
99	Backup	10.24.99.0/24	10.24.99.1	10.24.99.1	10.24.99.31	non applicabile	30	backup server, replica dati
50	Reparto E	10.24.50.0/24	10.24.50.1	10.24.50.1	10.24.50.15	10.24.50.10	14	PC project management
80	Management	10.24.80.0/24	10.24.80.1	10.24.80.1	10.24.80.15	non applicabile	14	apparati, console amministrazione

Piano ulteriormente semplificato, senza
VLAN 90 - WiFi ospiti
VLAN 99 - Backup
VLAN 70 - Servizi locali

VLAN	Nome Rete	Subnet	Gateway	Router / interfaccia VLAN	Broadcast	Primo IP disponibile per PC utente	Host utilizzabili	Dispositivi principali
30	Reparto C	10.24.30.0/24	10.24.30.1	10.24.30.1	10.24.30.15	10.24.30.2	126	PC C, File Server C, Stampante C
10	Reparto A	10.24.10.0/24	10.24.10.1	10.24.10.1	10.24.10.63	10.24.10.2	62	PC A, File Server A, Stampante A
20	Reparto B	10.24.20.0/24	10.24.20.1	10.24.20.1	10.24.20.63	10.24.20.2	62	PC B, File Server B, Stampante B
40	Reparto D	10.24.40.0/24	10.24.40.1	10.24.40.1	10.24.40.31	10.24.40.2	30	PC test qualità
60	Reparto F	10.24.60.0/24	10.24.60.1	10.24.60.1	10.24.60.31	10.24.60.2	30	PC amministrazione
50	Reparto E	10.24.50.0/24	10.24.50.1	10.24.50.1	10.24.50.15	10.24.50.2	14	PC project management

8. Policy di comunicazione tra reparti

La regola generale è “deny by default”: tutto il traffico tra VLAN è bloccato, salvo ciò che viene esplicitamente consentito.

Sorgente	Destinazione	Servizi consentiti	Motivo
Reparto A	Internet	HTTP/HTTPS, DNS controllato	navigazione sviluppatori
Reparto A	File server A	SMB/NFS o HTTPS interno	lavoro sui file del reparto
Reparto A	Stampante A	IPP/LPD/RAW secondo modello	stampa di reparto
Reparto A	Server B/C	negato	isolamento tra reparti
Reparto B	Internet, File server B, Stampante B	servizi analoghi ad A	lavoro reparto B
Reparto B	Server A/C	negato	isolamento
Reparto C	Internet, File server C, Stampante C	servizi analoghi ad A	lavoro reparto C
Reparto C	Server A/B	negato	isolamento
Reparto D	File server A/B/C	SMB/NFS con permessi specifici	test qualità e report
Reparto D	Internet	opzionale e filtrato	documentazione/test
Reparto E	File server A/B/C	accesso completo controllato	project management
Reparto E	Repository sede centrale	HTTPS/SFTP/SSH/Git over HTTPS	trasferimento versioni finali
Reparto F	Internet	HTTP/HTTPS, DNS	amministrazione
Reparto F	Gestionale sede centrale	HTTPS o client applicativo su VPN	gestione sede
Management	Apparati e server	SSH, HTTPS admin, SNMPv3	amministrazione tecnica
Ospiti	Internet	solo HTTP/HTTPS/DNS	nessun accesso interno

9. Autenticazione degli utenti

L'accesso ai computer deve avvenire previa autenticazione.

Una soluzione può essere un "dominio" aziendale locale o integrato con la sede centrale, basato su Active Directory oppure LDAP/Kerberos.

Gli utenti accedono con credenziali personali. I gruppi principali sono:

DEV_A, DEV_B, DEV_C, TEST_QA, PROJECT_MANAGER, ADMIN_SEDE, IT_ADMIN.

I permessi sui file server vengono assegnati ai **gruppi**, non ai singoli utenti, perché la gestione è più ordinata e scalabile.

Esempio sui file server:

File server A:

DEV_A lettura/scrittura sulle cartelle di lavoro,

TEST_QA accesso alle aree da validare con possibilità di scrivere report e rinominare cartelle

PROJECT_MANAGER accesso completo operativo, altri reparti negati.

10. Misure di sicurezza interna ed esterna

Le principali misure di sicurezza adottate nella rete interna aziendale sono:

- segmentazione tramite VLAN per isolare logicamente reparti e servizi;
- ACL e firewall interni per controllare il traffico tra VLAN;
- autenticazione centralizzata degli utenti tramite sistemi come Active Directory o RADIUS;
- autorizzazioni basate su gruppi e ruoli;
 - Ricordiamo che per semplicità a volte un ruolo organizzativo ("amministrazione", "docente", "tecnico", "HR", "manager") viene implementato tramite uno o più gruppi e le autorizzazioni vengono assegnate ai gruppi, ciò accade soprattutto nelle applicazioni business.
- autenticazione 802.1X sulle porte degli switch;
- disabilitazione delle porte switch inutilizzate;
- DHCP snooping (awitch accetta risposte DHCP solo da server autorizzati, bloccando eventuali server DHCP falsi o malevoli presenti nella rete.);
- Dynamic ARP Inspection contro attacchi ARP spoofing;
 - Inspection: controllare ogni messaggio ARP per verificare che l'associazione IP-MAC dichiarata coincida con quella registrata come valida nella tabella ottenuta dal DHCP **autorizzato**; in caso contrario il pacchetto ARP viene bloccato.
- logging centralizzato per monitoraggio e audit;
- backup periodici dei dati e delle configurazioni;
- antivirus/EDR sui client aziendali;
- aggiornamenti centralizzati di sistemi e software per correggere vulnerabilità.

Sicurezza esterna:

- firewall/NGFW, NAT per l'uscita Internet,
- VPN IPsec site-to-site verso sede centrale,
- filtraggio DNS o proxy, IDS/IPS,
- blocco degli accessi amministrativi da Internet,
- monitoraggio dei log,
- MFA per accessi amministrativi e remoti.

La scelta più importante è separare rete utenti, rete server, rete management e rete ospiti. In questo modo un problema su un

reparto non consente automaticamente di raggiungere tutti gli altri sistemi.

11. Collegamento verso la sede centrale

Il collegamento tra nuova sede e sede centrale viene realizzato **tramite VPN IPsec site-to-site** tra i due firewall aziendali.

Motivi:

- la sede è in città diversa, quindi il traffico passa su rete geografica o Internet;
- i dati trasferiti, progetti software, documentazione, dati amministrativi, possiamo considerarli riservati
- serve cifratura, autenticazione dei peer e controllo degli indirizzi raggiungibili.

Traffico consentito sulla VPN:

Sorgente nuova sede	Destinazione sede centrale	Protocollo	Uso
Reparto E	Project repository	HTTPS 443, SSH 22, SFTP 22 o Git	trasferimento versioni finali
Reparto F	Gestionale remoto	HTTPS	gestione amministrativa
Server locali	Servizi directory centrali	HTTPS 443 o porta applicativa specifica	integrazione autenticazione
Management IT	Servizi directory centrali	LDAP/LDAPS, Kerberos, DNS, NTP se necessari	amministrazione
	apparati autorizzati	SSH/HTTPS/SNMPv3	

Il repository remoto non viene esposto direttamente a Internet: viene raggiunto attraverso VPN, oppure tramite HTTPS aziendale con autenticazione forte. In una soluzione d'esame è preferibile indicare VPN site-to-site, perché collega stabilmente le due sedi e consente policy chiare.

12. Schema logico della VPN

Nuova sede

Rete LAN: 10.24.0.0/16

|
Firewall / VPN Gateway IPsec

IP pubblico sede nuova

|
=====

Tunnel IPsec site-to-site
cifratura e autenticazione

=====

|
Firewall / VPN Gateway IPsec

IP pubblico sede centrale

|
Reti sede centrale
10.10.0.0/16

|-- Project repository: 10.10.20.10

|-- Gestionale: 10.10.30.10

Regole principali:

10.24.50.0/28 può raggiungere 10.10.20.10,

10.24.60.0/27 può raggiungere 10.10.30.10,

le altre VLAN non accedono ai server centrali salvo necessità documentata.

13. Configurazione di un servizio: file server dei reparti

Si dettaglia il servizio file server, perché è centrale nella traccia.

Ogni reparto A, B e C ha un file server dedicato o una VM dedicata.

Il servizio può essere SMB/CIFS in ambiente Windows oppure Samba in ambiente Linux integrato con dominio.

Esempio per File Server A:

nome server: FS-A

IP: 10.24.11.10

share principale: \FS-A\progetti_A

gruppi autorizzati:

DEV_A: lettura/scrittura sui progetti in lavorazione;

TEST_QA: lettura sui progetti e scrittura nella sottocartella report_test; possibilità controllata di rinomina

PROJECT_MANAGER: accesso completo alle versioni finali;

IT_ADMIN: amministrazione tecnica.

Struttura cartelle:

\\FS-A\progetti_A

\In_Lavorazione

\In_Test

\Finali

\Report_Test

Permessi consigliati:

Cartella	DEV_A	TEST_QA	PROJECT_MANAGER	IT_ADMIN
In_Lavorazione	modifica	nessun accesso o lettura	lettura	controllo completo
In_Test	modifica	lettura/scrittura report	lettura	controllo completo
Finali	lettura	scrittura controllata/rename tramite procedura	modifica	controllo completo
Report_Test	lettura	scrittura	lettura/scrittura	controllo completo

Per la richiesta “rinominare la cartella aggiungendo _Final_Version e renderla read-only”, è preferibile non lasciare libertà completa ai tester su tutto il file server. La soluzione più ordinata è prevedere una procedura o script controllato, eseguito con permessi adeguati, che:

- verifica che il tester appartenga al gruppo TEST_QA,
- controlla che il progetto sia in stato “test superato”,
- scrive il report nella cartella,
- rinomina la cartella aggiungendo _Final_Version,
- modifica i permessi rendendo la cartella non più modificabile dagli sviluppatori.

Esempio di logica operativa:

Progetto_X

dopo test superato:

Progetto_X_Final_Version

A quel punto:

DEV_A: sola lettura o nessuna modifica;

TEST_QA: sola lettura dopo chiusura;

PROJECT_MANAGER: lettura e trasferimento al repository centrale;

IT_ADMIN: controllo completo.

14. Esempio di configurazione logica del trasferimento al repository

Quando una versione è marcata come finale, i project manager trasferiscono il contenuto al repository centrale. (Nella realtà è assurdo, dovrebbe farlo personale DevOps congiuntamente a personale dello sviluppo come supporto, DevOps sono sistemisti specializzati nella gestione e automazione dello sviluppo)

Protocollo consigliato:

- Git over HTTPS se si tratta di codice sorgente versionato;
- SFTP (usa SSH) o FTPS (FTP + TLS) se si tratta di pacchetti, documentazione, manuali o archivi;
- HTTPS verso piattaforma repository aziendale se il sistema remoto è GitLab, Bitbucket Server o simile.

Esempio:

repository centrale: 10.10.20.10

accessibile solo dalla VLAN 50 tramite VPN

autenticazione: credenziali personali + MFA

log: tutti i trasferimenti registrati

backup: repository centrale sottoposto a backup periodico.

15. Sintesi delle scelte adottate

VLAN separate perché i reparti hanno requisiti di accesso diversi.

- I file server sono separati per reparto perché la traccia richiede isolamento tra A, B e C.

- Il reparto D riceve accessi specifici per il test qualità, non accesso generale alla rete.

- Il reparto E ha accesso più ampio perché deve consolidare le versioni finali e inviarle al repository centrale.

- Il reparto F (gestione tecnica) ha accesso al gestionale remoto e a Internet, ma non ai sistemi tecnici degli sviluppatori.

La VPN site-to-site è la scelta più coerente per collegare sedi diverse in modo sicuro. Il firewall/NGFW è il punto principale di controllo, mentre la directory centralizzata garantisce autenticazione e autorizzazioni coerenti.

Seconda parte

SECONDA PARTE - Quesito I

Presso la **sede centrale** per i server pubblici la scelta più corretta è realizzare una DMZ, nella quale collocare i servizi raggiungibili da Internet: server web e-commerce e server mail.

Schema:

Internet

|
Router ISP

|
Firewall perimetrale / NGFW

|
|-- DMZ

|
|-- Web server e-commerce

|
|-- Mail server / mail gateway

|
|-- LAN sede centrale

|
|-- Project repository

|
|-- Sistema gestionale

|
|-- Database interni

|
|-- Postazioni utenti

Il server web e-commerce non deve accedere liberamente alla LAN interna.

Se deve consultare dati aziendali, ad esempio prodotti, ordini o disponibilità, è preferibile usare un **application server o API server intermedio**, con regole firewall molto restrittive. Il database gestionale, e in generale tutti i server che non necessitano di esposizione pubblica, non va esposto direttamente in DMZ.

Il server mail può essere collocato in DMZ come mail gateway, mentre le caselle effettive possono stare su server interno o su servizio cloud.

Il gateway riceve e invia posta tramite SMTP, applica antispam, antivirus e controlli sui messaggi, poi inoltra verso il sistema interno.

Più in dettaglio - il server SMTP esposto verso Internet viene spesso collocato nella DMZ, perché deve comunicare con server di posta esterni;

- il server POP3/IMAP può essere: - interno oppure - pubblicato in DMZ se accessibile anche dall'esterno. NB spesso SMTP e POP3/IMAP non sono server separati ma servizi **dello stesso mail server**.

Porte indicative da consentire:

Servizio web: HTTP 80 e HTTPS 443 verso il web server,

preferibilmente solo HTTPS per gli utenti finali.

eMail

* SMTP porta 25: ricezione e invio della posta **tra mail server**; * SMTP porta 587: invio autenticato dei messaggi da parte degli utenti; * IMAPS porta 993: lettura sicura della posta direttamente dal server aziendale.

Accessi amministrativi: solo da rete management o tramite VPN, mai direttamente da Internet.

PlantUML:

Motivo della scelta: la DMZ limita i danni in caso di compromissione di un server pubblico. Un attaccante che compromettesse il web server non dovrebbe poter raggiungere direttamente file server, repository, gestionale o database interni.

SECONDA PARTE - Quesito II

La virtualizzazione dei server locali su un unico server fisico modifica soprattutto la parte server della nuova sede. Invece di avere più server fisici separati, si installa un server fisico potente con hypervisor e più macchine virtuali.

Server virtualizzabili:

- file server reparto A,
- file server reparto B,
- file server reparto C,
- eventuale server autenticazione locale, - server backup locale, - server monitoraggio.

La rete logica deve rimanere separata.

Anche se i server sono nello stesso host fisico, le VM devono continuare ad appartenere a VLAN diverse.

Esempio di assegnazione delle macchine virtuali:

- VM File Server reparto A → VLAN Server A;
- VM File Server reparto B → VLAN Server B;
- VM File Server reparto C → VLAN Server C;
- VM autenticazione/ dominio → VLAN Servizi;
- VM backup → VLAN Backup oppure VLAN Management;
- VM monitoraggio → VLAN Management o Servizi.

Modifiche fisiche consigliate:

- server fisico con almeno 16 core CPU, per eseguire contemporaneamente più macchine virtuali mantenendo buone prestazioni;
- almeno 64 GB di RAM, per assegnare memoria sufficiente alle VM di file server, autenticazione, backup e monitoraggio;
- storage ridondato RAID 1 o RAID 10 con almeno 4 TB totali su dischi SSD o enterprise HDD, per garantire continuità operativa e maggiore affidabilità dei dati;
- doppio alimentatore ridondato da almeno 750 W collegato a linee protette da UPS online da almeno 3000 VA, per mantenere operativo il server durante guasti o blackout;
- almeno 2 schede di rete Gigabit Ethernet o 10 Gigabit Ethernet, per separare traffico dati, management e backup oppure realizzare ridondanza;
- collegamenti ridondati verso due switch distinti tramite almeno 2 link Ethernet configurati in bonding/LACP, per aumentare affidabilità e disponibilità;
- sistema di backup esterno con NAS dedicato da almeno 8 TB oppure backup remoto/cloud, per consentire il ripristino delle VM e dei dati in caso di guasti o attacchi ransomware.

Modifiche logiche consigliate:

creazione di virtual switch sull'hypervisor, trunk 802.1Q tra switch fisico e server di virtualizzazione, assegnazione di una VLAN a ogni VM, regole firewall identiche a quelle previste per server fisici, snapshot solo per manutenzione temporanea, backup regolari delle VM.

Schema:



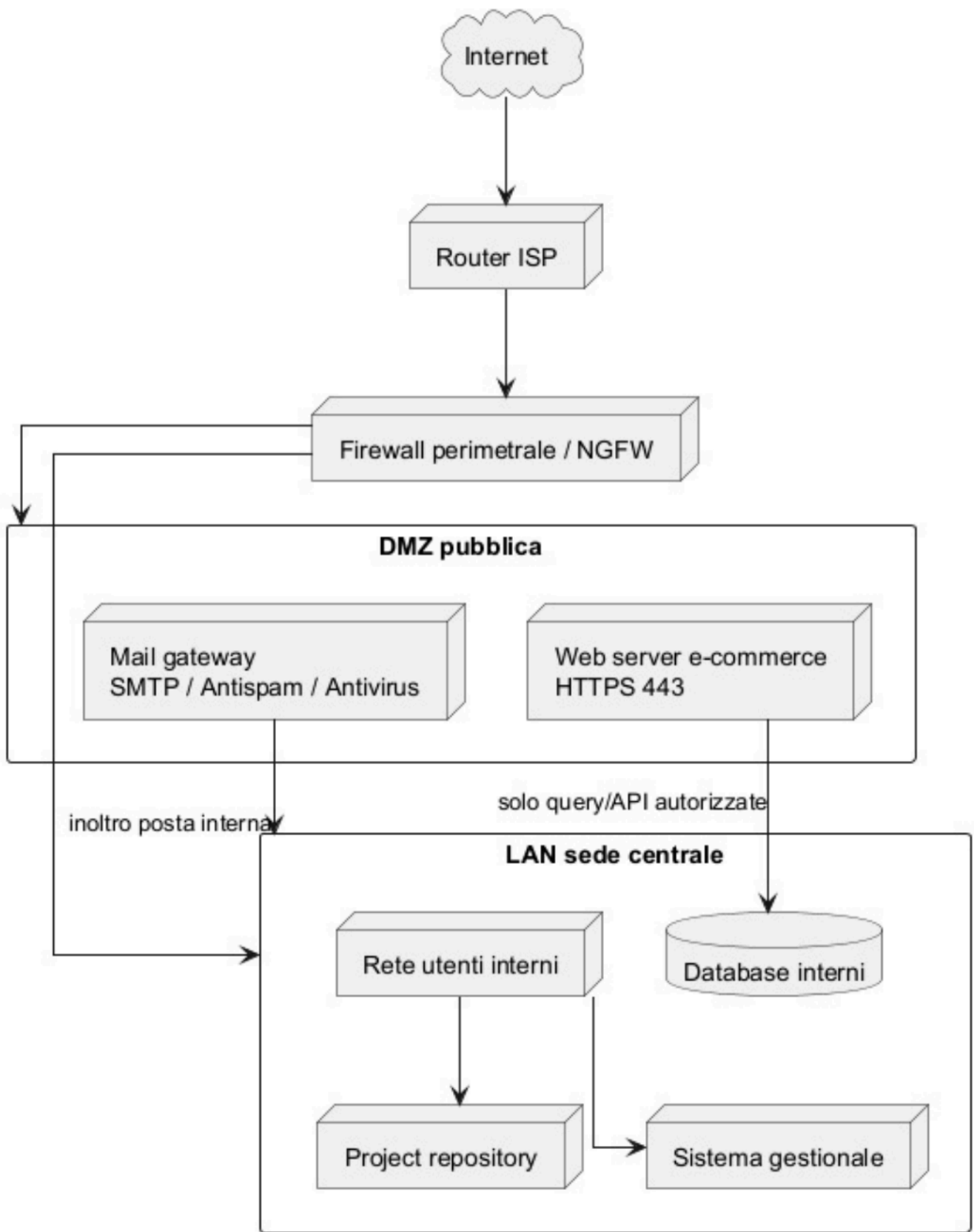
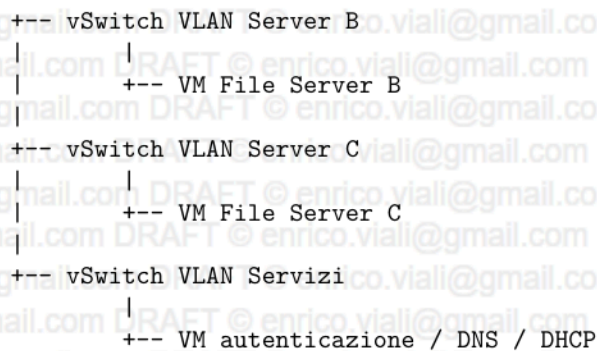


Figure 2: PlantUML 2



NB in una infrastruttura virtualizzata il server fisico con hypervisor viene normalmente collegato direttamente allo switch centrale tramite una o più interfacce Ethernet fisiche. Su quel collegamento transitano le diverse VLAN mediante trunk IEEE 802.1Q.

PlantUML:

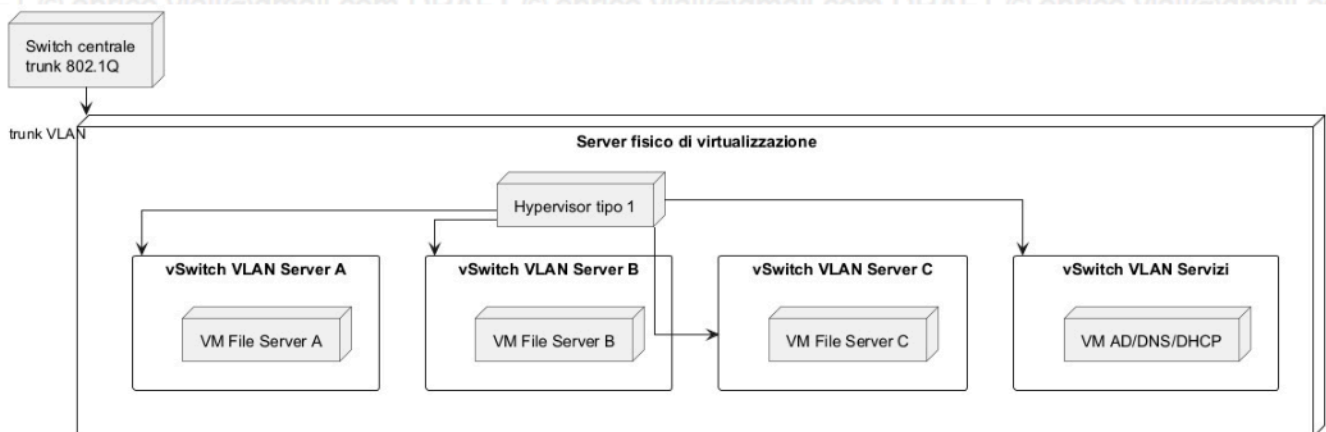


Figure 3: PlantUML 3

Differenza tra hypervisor tipo 1 e tipo 2:

Tipo 1: installato direttamente sull'hardware fisico, **senza sistema operativo** ospitante tradizionale. È più adatto ai server aziendali perché offre **migliori prestazioni**, maggiore isolamento e gestione più **professionale**.

Tipo 2: installato sopra un sistema operativo già esistente, ad esempio Windows o Linux desktop. È più adatto a laboratori, test e uso didattico, ma meno indicato per server di produzione.

Esempi:

tipo 1: VMware ESXi, Microsoft Hyper-V Server e Proxmox VE

tipo 2: VirtualBox, VMware Workstation, Parallels

SECONDA PARTE - Quesito III

I protocolli di sicurezza WiFi si sono evoluti perché le prime soluzioni erano deboli e facilmente attaccabili.

WEP

ormai insicuro. Usa meccanismi crittografici deboli e può essere violato con strumenti comuni. Non deve essere usato in una rete aziendale.

WPA

soluzione transitoria per superare WEP.

Migliora la sicurezza, ma oggi è superato e **non dovrebbe essere scelto** per una nuova infrastruttura.

WPA2

è stato per anni lo standard principale.

Con WPA2-Personal si usa una password condivisa; è adatto a reti domestiche o piccole reti non critiche.

Con WPA2-Enterprise si usa autenticazione **individuale**, normalmente tramite server RADIUS e credenziali personali.

Per un'azienda, WPA2-Enterprise è molto più corretto di WPA2-Personal.

WPA3

evoluzione più recente. Offre protezione più forte per ambienti aziendali e può usare configurazioni crittografiche più robuste.

Scelta per questo caso d'uso:

nella sede aziendale è opportuno usare WPA2-Enterprise o WPA3-Enterprise, con autenticazione **personale** degli utenti, integrazione con directory aziendale e separazione in VLAN.

Esempio di reti WiFi:

SSID aziendale dipendenti: WPA2/WPA3-Enterprise, autenticazione individuale, accesso alle VLAN autorizzate.

SSID ospiti: rete separata, solo Internet, captive portal o password temporanea, nessun accesso ai sistemi interni.

SSID tecnico/management: eventualmente presente, ma molto limitato e accessibile solo ad amministratori.

La scelta Enterprise è coerente con il requisito di autenticazione degli utenti: ogni dipendente deve accedere con credenziali personali, non con una password WiFi condivisa.

SECONDA PARTE - Quesito IV

Un firewall controlla il traffico tra **reti diverse** applicando regole di sicurezza.

Nel caso della prova serve

- sia per proteggere la sede locale,
- sia **per separare i reparti**,
- sia per controllare il collegamento verso Internet e verso la sede centrale.

Tipi principali di firewall:

Packet filtering firewall/stateless: controlla pacchetti in base a indirizzi IP, porte e protocolli. È semplice e veloce, ma non comprende il contenuto applicativo.

Stateful firewall: tiene conto dello stato delle connessioni. È più sicuro del semplice packet filtering perché distingue, ad esempio, una connessione legittima già aperta da un pacchetto isolato non atteso.

NGFW Next Generation Firewall:

integra funzioni più avanzate, come controllo applicativo, IPS, filtraggio URL, ispezione del traffico e integrazione con utenti o gruppi.

Suddivisione basata su impiego: - Edge/perimeter firewall

Separazione/Protezione rispetto a WAN (internet)

- Firewall interno (o di segmentazione):

separa reparti, server e reti amministrative. Qui è importante perché i reparti A, B e C non devono accedere tra loro, mentre D ed E devono avere permessi specifici sui file server.

Application gateway / proxy:

Un proxy lavora a livello applicativo. Non si limita a vedere indirizzo IP e porta, ma interpreta il protocollo applicativo, ad esempio HTTP o HTTPS.

Può filtrare siti, registrare accessi, applicare policy aziendali, bloccare contenuti non ammessi e migliorare il controllo sulla navigazione.

Differenza essenziale:

- il firewall decide se un traffico tra reti è consentito o bloccato,
- il proxy agisce come intermediario applicativo tra client e servizio richiesto.

Utilizzo nel nostro scenario:

Firewall perimetrale: protegge l'accesso Internet e gestisce NAT, VPN, regole in ingresso e uscita.

Firewall interno o regole ACL: impedisce il traffico non autorizzato tra reparti.

Proxy web: controlla la navigazione Internet degli utenti aziendali.

WAF: protegge il sito e-commerce della sede centrale da attacchi applicativi come SQL injection, XSS e richieste HTTP anomale.

IDS/IPS: rileva o blocca traffico sospetto, utile sia sul perimetro sia tra zone interne importanti.

In sintesi: per questa azienda non basta un solo firewall "verso Internet".

È necessario anche controllare il traffico cioè tra reparti e server interni (a volte chiamato Est-Ovest) perché sono richiesti permessi diversi per sviluppatori, tester, project manager e amministrazione.